

. We rely on GitLab's Tech Stack by default, however this can be updated by the Identity Operations team to be the domain subject matter expert (SME) for the specific configuration.

The merge request is automatically merged after all approvals are provided. Approval should not be provided until changes are ready to go live.

When the branch is merged into the main branch, the terraform apply job is included in the CI/CD pipeline and is run automatically if the terraform plan job passes and the changes go live automatically.

Standardized Modules and Syntax

We have a library of pre-defined modules (configuration templates) that allow us to simply define a few variables in a module configuration block and all of the other syntax is handled within the module for standardization.

Each module can be used in the appropriate Terraform configuration file. See the respective vendor repository for more details.

SECTION: security/identity/boundaries/_index.md

Security Risk Disclaimer

As part of our transparency, we share this high level explanation of what we do, but do not publicly share the details of how we do it. By exposing this high-level overview, we tend to hear feedback from the community about shortcomings that we can remediate to improve our posture.

The world's source code is more secure when we collaborate on best practices together. If you are able to penetrate this, we'd love to talk to you about joining our team.

Please report any vulnerabilities using our bug bounty and responsible disclosure process.

Castle Walls

Administrative Kingdoms

mermaid
graph TB

subgraph Jamf MDM Profile
subgraph SentinelOne EDM Monitoring
subgraph Separate BLACK 1Password User Account and Vault
subgraph Separate BLACK Okta User Account
subgraph Separate BLACK Google Workspace User Account
subgraph Okta Verify Device Trust
subgraph Okta Hardware 2FA with YubiKey
subgraph NordLayer VPN with Dedicated Gateway Static IPs

- itanalyst:
 - teamname: 'IT End User Services (aka Analysts / Helpdesk)'
 - responsibilities:
 - TODO
 - manager: mbeltran
 - counterparts:
 - jwong
 - gitlabsaastag: '@gitlab-com/it/end-user-services'
 - slackchannel: 'ithelp'
 - handbookpage: 'https://handbook.gitlab.com/handbook/business-technology/end-user-services/'
 - issue tracker: null
- itcompliance:
 - teamname: 'IT Compliance'
 - responsibilities:
 - TODO
 - manager: disla
 - counterparts:
 - disla
 - gitlabsaastag: '@gitlab-com/it/compliance'
 - slackchannel: 'ithelp'
 - handbookpage: 'https://handbook.gitlab.com/handbook/business-technology/enterprise-applications/it-compliance/'
 - issue tracker: 'https://gitlab.com/gitlab-com/business-technology/change-management/-/issues'
- itopsleader:
 - teamname: 'IT Ops Leadership'
 - responsibilities:
 - TODO
 - manager: rrea
 - counterparts:
 - rrea
 - gitlabsaastag: '@rrea1'
 - slackchannel: 'ithelp'
 - handbookpage: null
 - issue tracker: null
- itseceng:
 - teamname: 'IT Security and Engineering'
 - responsibilities:
 - TODO
 - manager: erubin
 - counterparts:
 - erubin
 - mwhitaker
 - malkobaisy
 - gitlabsaastag: '@gitlab-com/it/security @gitlab-com/it/engops'
 - slackchannel: 'itsecurityhelp'
 - handbookpage: 'https://handbook.gitlab.com/handbook/security/corporate/'
 - issue tracker: 'https://gitlab.com/gitlab-com/it/security/issue-tracker/-/issues'
- infraplatformsleader:
 - teamname: 'Infrastructure SaaS Platforms Leadership'
 - responsibilities:

- TODO
- manager: marin
- counterparts:
 - marin
- gitlabsaasgrouptag: '@marin'
- slackchannel: 'splatforms'
- handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure/platforms/'
- issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/mstaff/-/issues'
- infrafoundations:
 - teamname: 'Production Engineering Foundations'
 - responsibilities:
 - TODO
 - manager: sabrams
 - counterparts:
 - sabrams
 - gitlabsaastag: '@sabrams'
 - slackchannel: 'gfoundations'
 - handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure-platforms/production-engineering/foundations/'
 - issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/production-engineering/-/issues'
- infraops:
 - teamname: 'Production Engineering Ops'
 - responsibilities:
 - TODO
 - manager: glopezfernandez
 - counterparts:
 - glopezfernandez
 - gitlabsaastag: '@glopezfernandez'
 - slackchannel: 'ginfrageneral'
 - handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/reliability/general.html'
 - issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/production-engineering/-/issues'
- infrascalabilityleader:
 - teamname: 'Scalability Leadership'
 - responsibilities:
 - TODO
 - manager: rnienaber
 - counterparts:
 - rnienaber
 - gitlabsaastag: '@rnienaber'
 - slackchannel: 'gscalability'
 - handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/scalability/'
 - issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/scalability/-/issues'
- infraobservability:
 - teamname: 'Scalability Observability'
 - responsibilities:
 - TODO
 - manager: 'Imcandrew'
 - counterpart: 'Imcandrew'

gitlabsaastag: '@lmcandrew'
slackchannel: 'gscalability'
handbookpage:
'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/scalability/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/scalability/-/issues'

- infrapractices:
teamname: 'Scalability Practices'
responsibilities:
- TODO
manager: kwanyangu
counterparts:
- kwanyangu
gitlabsaastag: '@kwanyangu'
slackchannel: 'gscalability'
handbookpage:
'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/scalability/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/scalability/-/issues'

- infradeployment:
teamname: 'Delivery Deployment System'
responsibilities:
- TODO
manager: dsmith
counterparts:
- dsmith
gitlabsaastag: '@dawsmith'
slackchannel: 'gdelivery'
handbookpage:
'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/delivery/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/delivery/-/issues'

- infraorchestration:
teamname: 'Delivery Release Orchestration'
responsibilities:
- TODO
manager: mbursi
counterpart:
- mbursi
gitlabsaastag: '@mbursi'
slackchannel: 'gdelivery'
handbookpage:
'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/delivery/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/delivery/-/issues'

- infradicatedgeneral:
teamname: 'Dedicated Leadership'
responsibilities:
- TODO
manager: aphilips
counterpart:
- aphilips
gitlabsaastag: '@aphillips'
slackchannel: 'gdedicated-team'

handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/gitlab-dedicated/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/gitlab-dedicated/team/-/issues'

- infradicatedenvautomation:
teamname: 'Dedicated Environment Automation'
responsibilities:
- TODO
manager: olluch
counterparts:
- olluch
gitlabssaastag: '@o-lluch @gitlab-dedicated/environment-automation'
slackchannel: 'gdedicated-team'
handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/gitlab-dedicated/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/gitlab-dedicated/team/-/issues'

- infradicatedswitchboard:
teamname: 'Dedicated Switchboard'
responsibilities:
- TODO
manager: ashriel
counterpart:
- ashriel
gitlabssaastag: '@ashriel'
slackchannel: 'gdedicated-switchboard-team'
handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/gitlab-dedicated/switchboard/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/gitlab-dedicated/team/-/issues'

- infradicatedswitchboard:
teamname: 'Dedicated US Public Sector Services'
responsibilities:
- TODO
manager: sdumesnil
counterpart: sdumesnil
gitlabssaastag: '@sdumesnil'
slackchannel: 'gdedicated-us-pubsec'
handbookpage: 'https://handbook.gitlab.com/handbook/engineering/infrastructure/team/gitlab-dedicated/us-public-sector-services/'
issue tracker: 'https://gitlab.com/gitlab-com/gl-infra/gitlab-dedicated/team/-/issues'

- peopleopstechnology:
teamname: 'People Ops Technology and Tools'
responsibilities:
- TODO
manager: achan
counterpart: aromaniello
gitlabssaastag: '@ajrom'
slackchannel: 'people-connect|peopleops-eng'
handbookpage: 'https://handbook.gitlab.com/handbook/people-group/engineering/'
issue tracker: 'https://gitlab.com/gitlab-com/people-group/peopleops-eng/people-group-engineering/-/issues'

- seccompliancecommercial:

teamname: 'Security Compliance (Commercial)'

responsibilities:

- Access Management Policy
- Quarterly and Annual Audits
- User Access Reviews

managers:

- jburrows
- lcoleman

counterparts:

- afrank
- deckhardt
- bboots
- mlake

gitlabsaastag: '@gitlab-com/gl-security/security-assurance/team-commercial-compliance'

slackchannel: 'sec-assurance'

handbookpage: 'https://handbook.gitlab.com/handbook/security/security-assurance/security-compliance/'

issuetracker: 'https://gitlab.com/gitlab-com/gl-security/security-assurance/team-commercial-compliance/compliance'

- secidentityeng:

teamname: 'Identity Engineering (Architecture and Platform)'

responsibilities:

- Architect next-generation IAM and access management standards
- Build automation and integration between systems that provides data consistency, reliability, strong security, and audibility.
- Consolidate and refactor legacy data, processes, and tech debt.
- Design and document processes with automation mindset to improve back office operations.
- Efficiency optimization is our North Star.
- Factor in cost, security, compatibility, maintainability and user experience when making decisions.

manager: smanzuik

counterparts:

- jmartin

gitlabsaastag: '@gitlab-com/gl-security/identity/eng'

slackchannel: 'security-identity-eng'

handbookpage: 'https://handbook.gitlab.com/handbook/security/threat-management/identity/eng/'

issuetracker: 'https://gitlab.com/gitlab-com/gl-security/identity/eng/issue-tracker/-/issues'

- secidentityinfra:

teamname: 'Identity Infrastructure'

responsibilities:

- Administrative control plane architecture
- AWS and GCP infrastructure organization-level management
- Cloud infrastructure organizational management and least privilege security
- Infrastructure service accounts
- Infrastructure user access requests

manager: smanzuik

counterparts:

- vstoianovici

gitlabsaastag: '@gitlab-com/gl-security/identity/infra'

slackchannel: 'security-identity-ops'

handbookpage: 'https://handbook.gitlab.com/handbook/security/threat-management/identity/infra/'

issuetracker: 'https://gitlab.com/gitlab-com/gl-security/identity/infra/issue-tracker/-/issues'

- secidentityops:

teamname: 'Identity Operations'

responsibilities:

- Administrative access (BLACK accounts) and control plane change management
- Company-wide RBAC group and role management
- Escalation requests from counterpart teams
- Provisioning user access requests for administrative systems
- Role-based access control with just-in-time elevated access

manager: smanzuik

counterparts:

- jmartin
- vstoianovici

gitlabsaastag: '@gitlab-com/gl-security/identity/ops'

slackchannel: 'security-identity-ops'

handbookpage: 'https://handbook.gitlab.com/handbook/security/threat-management/identity/ops/'

issuetracker: 'https://gitlab.com/gitlab-com/gl-security/identity/ops/issue-tracker/-/issues'

- secinfra:

teamname: 'Infrastructure Security (aka InfraSec)'

responsibilities:

- AWS and GCP infrastructure organization-level policy enforcement
- Infrastructure vulnerability management
- Infrastructure configuration and best practices policies
- Production readiness reviews

manager: juliedavila

counterparts:

- djain
- mmorrison
- pmartins
- ugovindia

gitlabsaastag: '@gitlab-com/gl-security/security-operations/infrastructure-security'

slackchannel: 'security-infrasec'

handbookpage: 'https://handbook.gitlab.com/handbook/security/product-security/infrastructure-security/'

issuetracker: 'https://gitlab.com/gitlab-com/gl-security/security-operations/infrastructure-security/bau/-/issues'

- secsirt:

teamname: 'Security Incident Response Team (SIRT)'

responsibilities:

- TODO

managers:

- mcoons
- schoudhary
- vmairret

counterparts:

- ballam
- dperic

- hsharma
- mjozenazemian
- sgillespie

gitlabsaastag: '@gitlab-com/gl-security/security-operations/sirt'

slackchannel: 'security-division'

handbookpage: 'https://handbook.gitlab.com/handbook/security/security-operations/sirt/'

issuetracker: '/security'

<!-- ENDCOUNTERPARTSDIRECTORY -->

SECTION: security/identity/gitops/_index.md

Architecture Diagram

mermaid

graph TB

subgraph Identity Platform Control Plane

BLACKCITFAWS["Terraform AWS GitOps
gitops.gitlab.black/tf/aws/{org}"]:::yellow

BLACKCITFGCP["Terraform GCP GitOps
gitops.gitlab.black/tf/gcp/{org}"]:::yellow

BLACKCITFOKTA["Terraform Okta GitOps
gitops.gitlab.black/tf/okta"]:::yellow

subgraph AWS Identity Center SSO Permission Sets

BLACKAWSSERVICESORG["AWS Services Org"]:::sky

BLACKAWSSANDBOXORG["AWS Sandbox Org"]:::sky

BLACKAWSDEDICATEDORG["AWS Dedicated Org"]:::sky

BLACKAWSDEDICATEDDEVORG["AWS Dedicated Dev Org"]:::sky

BLACKAWSBLACKOPSORG["AWS Black Ops Org
Account per Service"]:::red

end

subgraph Google Cloud

BLACKGCPCOMORG["GCP Organization
gitlab.com"]:::sky

BLACKGCPCOMORGINFRAFOLDER["Infrastructure Folder
(GitLab SaaS Production)
Managed Infrastructure Department
ops.gitlab.net/gitlab-com/gl-infra/config-mgmt"]:::orange

BLACKGCPDEDIPRODORG["GCP Organization
Dedicated Prod"]:::sky

BLACKGCPDEDIDEVORG["GCP Organization
Dedicated Dev"]:::sky

BLACKGCPCOMORG --> BLACKGCPCOMORGINFRAFOLDER

end

subgraph Okta

BLACKOKTACOMORG["Okta Organization
gitlab.com"]:::sky

BLACKOKTACOMAPPS["Okta Applications"]:::sky

BLACKOKTACOMPOLICIES["Okta Policies"]:::sky

BLACKOKTACOMSETTINGS["Okta Settings"]:::sky

end

end

BLACKCITFAWS --> BLACKAWSSERVICESORG
BLACKCITFAWS --> BLACKAWSSANDBOXORG
BLACKCITFAWS --> BLACKAWSDEDICATEDORG
BLACKCITFAWS --> BLACKAWSDEDICATEDDEVORG
BLACKCITFAWS --> BLACKAWSBLACKOPSORG
BLACKCITFGCP --> BLACKGCPCOMORG
BLACKCITFGCP --> BLACKGCPDEDIPRODORG
BLACKCITFGCP --> BLACKGCPDEDIDEVORG
BLACKCITFOKTA --> BLACKOKTACOMORG
BLACKCITFOKTA --> BLACKOKTACOMAPPS
BLACKCITFOKTA --> BLACKOKTACOMPOLICIES
BLACKCITFOKTA --> BLACKOKTACOMSETTINGS

classDef slate fill:cbd5e1,stroke:475569,stroke-width:1px;
classDef red fill:fca5a5,stroke:dc2626,stroke-width:1px;
classDef orange fill:fdba74,stroke:ea580c,stroke-width:1px;
classDef yellow fill:fcd34d,stroke:ca8a04,stroke-width:1px;
classDef emerald fill:6ee7b7,stroke:059669,stroke-width:1px;
classDef cyan fill:67e8f9,stroke:0891b2,stroke-width:1px;
classDef sky fill:7dd3fc,stroke:0284c7,stroke-width:1px;
classDef violet fill:c4b5fd,stroke:7c3aed,stroke-width:1px;
classDef fuchsia fill:f0abfc,stroke:c026d3,stroke-width:1px;

SECTION: security/identity/gitops/aws/_index.md

{{% alert title="Work in Progress" color="danger" %}}

This page is a work-in-progress. Please check back later for up-to-date details.

{{% /alert %}}

SECTION: security/identity/gitops/gcp/_index.md

{{% alert title="Work in Progress" color="danger" %}}

This page is a work-in-progress. Please check back later for up-to-date details.

{{% /alert %}}

SECTION: security/identity/gitops/okta/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/security-and-technology-policies/access-management-policy/) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the roadmap in the [roadmap](#)

https://gitlab.com/groups/gitlab-com/gl-security/identity/eng/-/roadmap?state=all&sort=startdateasc&layout=QUARTERS&timeframerangetype=THREYEARS&group=gitlab-com/gl-security/identity/eng&progress=WEIGHT&showprogress=true&showmilestones=false&milestone_type=ALL&showlabels=true>epics gantt chart.

{{% /alert %}}

{{% alert title="GitOps Architecture and Approval Rules" color="info" %}}

This page is specific to the Okta backend configuration. You may also be interested in the Okta group and user provisioning documentation, Tech Stack application user guide and merge request approvals documentation.

{{% /alert %}}

Terraform Architecture

The Okta repository is used for managing any configuration that can be performed in the Admin UI. This moves all day-to-day administrative actions and global configuration into state management with MR approval rules and CI/CD automation.

```
mermaid
graph LR
  subgraph Identity GitLab Repositories
    subgraph Okta Terraform Repo
      subgraph Terraform Pipeline Jobs
        IDENTITYREPOTFCI["terraform apply"]
      end
      IDENTITYREPOTFOKTAAPPS["apps/{kingdom}/{appname}.tf"]
      IDENTITYREPOTFOKTASETTINGS["settings/{namespace}.tf"]
      IDENTITYREPOTFOKTAPOLICIES["policies/{namespace}.tf"]
      IDENTITYREPOTFOKTAAPPS --> IDENTITYREPOTFCI
      IDENTITYREPOTFOKTASETTINGS --> IDENTITYREPOTFCI
      IDENTITYREPOTFOKTAPOLICIES --> IDENTITYREPOTFCI
    end
  end
  subgraph Identity SaaS Vendor Services
    direction LR
    subgraph Okta GitLab Tenant
      direction TB
        IDENTITYVENDOROKTAAPIENDPOINT["Okta API<br />https://gitlab.okta.com/api/v1"]
        IDENTITYVENDOROKTAAPIAPPS["Okta Applications"]
        IDENTITYVENDOROKTAAPIGROUPS["Okta Groups<br />Data Source Only<br />Managed by accessctl"]
        IDENTITYVENDOROKTAAPIAPPGROUPS["Okta Application Groups"]
        IDENTITYVENDOROKTAAPIPOLICIES["Okta Policies"]
        IDENTITYVENDOROKTAAPISETTINGS["Okta Settings"]

        IDENTITYVENDOROKTAAPIENDPOINT --> IDENTITYVENDOROKTAAPIAPPS
        IDENTITYVENDOROKTAAPIENDPOINT --> IDENTITYVENDOROKTAAPIGROUPS
        IDENTITYVENDOROKTAAPIENDPOINT --> IDENTITYVENDOROKTAAPIAPPGROUPS
        IDENTITYVENDOROKTAAPIENDPOINT --> IDENTITYVENDOROKTAAPIPOLICIES
      end
    end
  end
```

```

IDENTITYVENDOROKTAAPIENDPOINT --> IDENTITYVENDOROKTAAPISETTINGS
end
IDENTITYREPOTFCI --> IDENTITYVENDOROKTAAPIENDPOINT
end

```

Okta Policies and Settings Configuration

The global settings and policies are managed in respective folders that are managed by the Identity kingdom.

```

| Configuration File          | CODEOWNERS          |
|-----|-----|
| admins/{handle}.tf         | secidentityops      |
| policies/{namespace}.tf | (2 Approvals) secidentityops secleader |
| settings/{namespace}.tf | (2 Approvals) secidentityops secleader |

```

Applications and Assigned Groups

GitLab's tech stack has hundreds of applications that are managed by a variety of business owners and technical owners.

The apps directory has a nested directory structure based on our Identity Kingdoms to accommodate different compliance requirements. Each application that the Kingdom owns has it's own file that specifies the application configuration and the Okta groups that are assigned to the application.

```

| Configuration File          | CODEOWNERS          |
|-----|-----|
| apps/identity/{appname}.tf | secidentityeng      |
| apps/businesssox/{appname}.tf | itopsleader        |
| apps/businessstack/{appname}.tf | Per-file based on tech stack business and technical owner |
| apps/productded/{appname}.tf | Per-file based on tech stack business and technical owner |
| apps/productdev/{appname}.tf | Per-file based on tech stack business and technical owner |
| apps/productprd/{appname}.tf | Per-file based on tech stack business and technical owner |
| apps/sandbox/{appname}.tf   | Per-file based on requester or service account owner.
|
| apps/services/{appname}.tf   | Per-file based on requester or service account owner.
|

```

Approval Rules

The configuration is broken into separate files based on the settings namespace or the kingdom that controls the specific resources.

We use CODEOWNERS for GitLab merge request (MR) approval rules to specify which Business Owner(s) and Technical Owner(s) can provide approval for changes to any given folder or file that contains configuration.

Since Okta groups and user memberships are managed outside of Terraform, the changes to state management are far and few between which simplifies auditability.

Learn more in the [merge request approvals documentation](#).

Application Users

We do not attach individually named users to applications. All users are assigned to groups and groups are assigned to applications.

You can attach three different categories of groups to applications:

1. Type (rbactype Group) This lets you attach a category of users (ex. employees, contractors, etc). At GitLab, we use the access level wristband color so access can be mass assigned to all blue, purple, brown, and black users.

1. Identity Role (rbacrole Group): This lets you attach users based on the functional team that they are on, usually specific to a job title and/or manager.

1. Identity Organizational Unit (rbacou Group): This lets you attach users that belong to a department, sub-department or other functional area with multiple inherited Identity Roles or other rulesets.

All groups and user assignments are managed by accessctl and user memberships are synced via Okta API with the existing Okta groups that match the names for each rbactype, rbacrole, or rbacgroup groups.

This provides separation of duties and control plane separation between "who is a member of which group" and "which groups are allowed to access each application". This prevents accessctl control plane from attaching or detaching groups from applications, and requires the application owner to configure and/or approve those changes in the application's Terraform configuration.

Automated Groups

When the scheduled background jobs run, accessctl will calculate the rbactype and rbacrole for each user based on the policy rulesets that are managed by the Identity team, and sync the user list with the existing Okta groups for each rbactype and rbacrole.

With predefined groups for each type of user and each job role, it is easy for application owners to "hard code" which roles have access to the applications for a "set it and forget it" configuration without managing user access requests day-to-day, while ensuring change management compliance.

Since the rbacrole policies are centrally and stringently managed by Identity team, this avoids the potential for teams or managers to create new groups that are arbitrarily or dynamically updated with additional users that should not have access.

Dynamic Policy Organization Unit Groups

An organization unit group can be used for departments, sub-departments, teams, or any other larger grouping of user that consists of two or more roles. Organization unit groups are managed by division and department leaders or people managers to help centrally manage and group functional areas together.

With an organization unit group, you can specify one or more roles, one or more user attributes, or specific user handles (useful for cross-functional users). To prevent recursive complexity, you cannot attach other organization unit groups. This simplifies maintenance since you can centrally manage each organization unit and don't need to maintain a list of roles in multiple places for each application.

Assigning Roles and Groups

Although organization units are managed with policies, there are a large number of contributors that may not fully understand the compliance and role-based access control implications for the systems that users can access.

For applications with strong permission or compliance requirements, application owners should only use the "trusted" rbactype or rbacrole groups. For applications that are less stringent and are considered "mass assignable", organization unit groups are easier to maintain.

You can use a combination of rbacrole and roleou groups as needed in the Terraform configuration.

Once you have defined the groups, the application owner does not need to handle day-to-day access requests since all access is automated. The only exception is if the system requires additional permissions to be granted inside the application once the user has signed in. We will consider iterating on this in the future on a system-by-system basis with the concept of Identity Blueprints which are provisioning scripts that use each vendor's API to grant access to specific resources.

Access Requests

If additional users need access, there are several approaches:

1. The user's attributes match the existing criteria of a role or organization unit that has already been attached to the Okta application. Access is automatically granted without a request.
1. The organization unit group policy CODEOWNER (ex. division leader or department manager or Executive Business Assistant) can update the policy in accessctl to include the additional role. The manifest of users for the organization unit is automatically recalculated and the users will be added to the organization unit Okta group that has already been attached to the application.
1. The application CODEOWNER can add the additional role group to the application using Terraform.

This provides improved maintenance since the division and department leaders or their delegate (ex. Executive Business Administrator) centrally manage the policies for organization unit

groups and which roles are members.

Since the users that are attached to each group are managed by accessctl policies and REST API calls (not Terraform), the changes to Terraform state management are far and few between which simplifies auditability.

Administrative User Access

Day-to-Day Administrator Access

Our Identity Engineering and Operations Okta system administrators and designated team members in IT and Security have Read Only Administrator role. They can request a temporary elevated (not Super Admin) role for break glass configuration changes using accessctl, however most changes will be performed in a Terraform MR.

Super Administrator (Root) Access

We have two super administrator user accounts that are an additional separate user account that is not managed in the centralized control plane that provides back door administrative access. These credentials are secured out-of-band in a vault that requires declaring an incident and requires Identity team two person rule approval to get access to ensure compliance.

We have additional security measures in place for these accounts:

- IP Address access control list (ACL) restricted to VPN known gateway addresses
- All audit logs for the super administrator event log actions (similar to key logger) are exported by default to our centralized logging system. We also programmatically parse all logs and add them the incident issue comment for transparency.
- After each break glass incident, the password is rotated automatically to ensure that credentials on the user's machine are no longer usable.

Additional details are intentionally obscured for security risk reasons.

SECTION: security/identity/guide/admin/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/app/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/audit/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/change-mgmt/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the Access Management Policy for the GitLab Identity v2 current state with baseline entitlements and access requests. See the Identity v3 roadmap to learn more about the future state.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/developer/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid

2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/incident/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/manager/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

{{% alert title="Not the guide you are looking for?" color="info" %}}

You are viewing the instructions for managing the access to applications, groups, and infrastructure for team members that report to you. To manage your own access, see the [end user guide](/handbook/security/identity/guide/user).

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/offboarding/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

{{% alert title="Not the guide you are looking for?" color="info" %}}

You are viewing the instructions for back office operations performed by Identity, IT, People, and Security Operations team members. We also have specific guides for [managers](/handbook/security/identity/guide/manager), new and existing team member [managers](/handbook/security/identity/guide/manager), new and existing team member [managers](/handbook/security/identity/guide/manager).

[end users](/handbook/security/identity/guide/user), and [auditors](/handbook/security/identity/guide/audit).
{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/onboarding/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

{{% alert title="Not the guide you are looking for?" color="info" %}}

You are viewing the instructions for back office operations performed by Identity, IT, People, and Security Operations team members. We also have specific guides for [managers](/handbook/security/identity/guide/manager), new and existing team member [end users](/handbook/security/identity/guide/user), and [auditors](/handbook/security/identity/guide/audit).

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/policy/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

{{% alert title="Not the guide you are looking for?" color="info" %}}

You are viewing the engineering deep-dive instructions for policy management. We also have specific guides for [managers](/handbook/security/identity/guide/manager), new and existing team member [end users](/handbook/security/identity/guide/user), [auditors](/handbook/security/identity/guide/audit) and [change management](/handbook/security/identity/guide/change-mgmt), [tech stack application system owners](/handbook/security/identity/guide/app), and [onboarding](/handbook/security/identity/guide/onboarding) and [offboarding](/handbook/security/identity/guide/offboarding) guides for Identity, IT, People, and Security Operations team members.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/guide/user/_index.md

{{% alert title="Not Live Yet" color="warning" %}}

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/access-management-policy) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the [Identity v3 roadmap](/handbook/security/identity/roadmap) to learn more about the future state.

{{% /alert %}}

{{% alert title="Not the guide you are looking for?" color="info" %}}

You are viewing the instructions for getting your own access to applications, groups, and infrastructure. If you are a people manager, we have a [manager's guide](/handbook/security/identity/guide/manager) for managing access for team members that report to you.

{{% /alert %}}

Quick Links

- TODO

Overview

This is a placeholder for an upcoming iteration.

Concepts

This is a placeholder for an upcoming iteration.

Runbooks

This is a placeholder for an upcoming instructions.

SECTION: security/identity/infrastructure/_index.md

<link rel="stylesheet" type="text/css" href="/stylesheets/biztech.css" />

Overview

All Cloud infrastructure with RED data is managed by the Infrastructure department. All demo/dev/test/sandbox/staging/production infrastructure for ORANGE/YELLOW/GREEN data is created by the Identity team using our self service portal or through issue templates.

Every team member can self-service create an AWS account and GCP project using the Sandbox Cloud for their own experimentation. This is your personal sandbox and is not shared with others.

We provision AWS accounts and GCP projects for each service/workload that more than one user has access to.

We believe in "one account/project per workload" for security blast radius and cost attribution reasons. Do not deploy different functional applications in the same AWS account or GCP project that has your team's name on it. You simply need to use the issue template to request a new AWS account or GCP project.

- Sandbox Cloud Documentation
- Self Service: Create an Individual AWS Account or GCP Project
- Issue Template: Create a Service/Team/Workload AWS Account
- Issue Template: Create a Service/Team/Workload GCP Project
- Issue Template: Add or Remove IAM Users from AWS Account
- Issue Template: Add or Remove IAM Users from GCP Project
- sandbox-cloud-questions for non-production infrastructure questions
- security-identity-ops and tag Jeff Martin or Vlad Stoianovici for organization-level questions

Identity Site Reliability Engineering

Since the Identity team manages our administrative access control plane with our BLACK accounts, we refer to this as the Black Ops Kingdom that includes the following services:

> For security reasons, any services with a .gitlab.black subdomain use an internal IP address that are only accessible with VPN access (BLACK account users) or for service accounts with addresses that have been added to the firewall ACL.

- (Future) ctl.gitlab.systems - Our instance of accessctl-ui self-service portal for team members (end users) that allows access without VPN using Okta and Okta Verify device trust. For security reasons, the self-service portal focuses on read-only functionality and creating requests, however has no administrative capabilities.
- (Internal IP) ctl.gitlab.black - Our internal instance of accessctl-api API for administrative operations using the CLI with a valid API token when connected to the VPN.
- (Internal IP) gitops.gitlab.black - Self-managed GitLab instance with accessctl-ci policies, manifests, changelogs, cloud infrastructure organization-level configuration, and Identity configuration pipelines. This instance is hardened for least privilege and is only accessible by designated Security team members.
- (Future) gitops.gitlab.systems - Terraform environments for Services Cloud (powered by HackyStack)
- gitops.gitlabsandbox.cloud - Terraform environments for Sandbox Cloud (powered by HackyStack)
- gitlabsandbox.cloud - Our instance of HackyStack that provides self-service access to AWS and GCP for team members.
- (Future) vault.gitlab.black - HashiCorp Vault instance
- (Future) teleport.gitlab.black - Teleport Bastion instance

mermaid
graph TB

subgraph Self Service Custom App Infrastructure

IDENTITYPLATFORMHACKYSTACK["HackyStack
Infrastructure Management
Sandbox and Ser Orgs"]

IDENTITYPLATFORMACCESSCTL["Identity Platform
Access Control (accessctl)
RBAC Policy Management
App/Group/User Provisioning"]

```
IDENTITYPLATFORMTRAININGMGR["Training Lab Manager<br />Product training Hands-on Labs<br />U
and Group Provisioning"]
end
```

```
subgraph Identity GitOps State Management Repos
```

```
end
```

```
subgraph Identity Self Hosted Vendor Services
```

```
IDENTITYHOSTEDOPSINSTANCE["ops.gitlab.black<br />Self-Managed GitLab Instance<br />Top-Level
Control Plane IaC"]
```

```
IDENTITYHOSTEDTELEPORT["Teleport<br />Bastion Cluster"]
```

```
IDENTITYHOSTEDHASHIVAULT["HashiCorp Vault<br />Secrets Manager"]
```

```
end
```

```
subgraph Identity SaaS Vendor Services
```

```
IDENTITYVENDOROKTA["Okta Tenant<br />gitlab.okta.com"]
```

```
IDENTITYVENDORGOOGWORKSPACECOM["Google Workspace Org<br />gitlab.com"]
```

```
IDENTITYVENDORGOOGWORKSPACEBLACK["Google Workspace Org<br />gitlab.black"]
```

```
IDENTITYVENDORGOOGWORKSPACEDEDICATEDDEV["Google Workspace Org<br />Dedicated Dev"]
```

```
IDENTITYVENDORGOOGWORKSPACEDEDICATEDPRD["Google Workspace Org<br />Dedicated Prod"]
```

```
IDENTITYVENDORGOOGWORKSPACESERVICESCLOUD["Google Workspace Org<br />gitlabservices.c
```

```
IDENTITYVENDORGOOGWORKSPACESANDBOXCLOUD["Google Workspace Org<br />gitlabsandbox.c
```

```
IDENTITYVENDORNORDLAYER["NordLayer VPN<br />VPN<br />Managed by IT Security"]
```

```
end
```

Cloud Provider Organization Management

The Identity Infrastructure team manages our top-level cloud provider infrastructure organization-level management for AWS and GCP in collaboration with the Infrastructure Security team.

Each team that deploys infrastructure resources is responsible for managing their own infrastructure workloads and DevOps operations using industry best practices. In other words, the Security team provides the scaffolding for your castle (Terraform templates) and provides hardened castle walls, while your team is responsible for anything you build inside the castle walls.

AWS Organizations

```
mermaid
graph LR
```

```
direction LR
```

```
IDENTITYAWSBILLING["AWS EDP Billing"]:::slate
```

```
IDENTITYAWSBLACKOPS["AWS Organization<br />Black Ops"]:::slate
```

```
IDENTITYAWSBLACKOPSACCOUNTS["Account per Workload"]:::slate
```

```
IDENTITYAWSDEDICATEDDEV["AWS Organization<br />Dedicated Dev x3675"]:::yellow
```

```

IDENTITYAWSDEDICATEDDEVACCOUNTS["Account per User"]:::yellow
IDENTITYAWSDEDICATEDPRD["AWS Organization<br />Dedicated Prd x0475"]:::red
IDENTITYAWSDEDICATEDPRDCONTROL["Control Plane Accounts"]:::red
IDENTITYAWSDEDICATEDPRDACCOUNTS["Account per Tenant Env"]:::red
IDENTITYAWSDEDICATEDPUBSEC["AWS Organization<br />Dedicated PubSec Prd x9885"]:::red
IDENTITYAWSDEDICATEDPUBSECCONTROL["Control Plane Accounts"]:::red
IDENTITYAWSDEDICATEDPUBSECACCOUNTS["Account per Tenant Env"]:::red
IDENTITYAWSSANDBOX["AWS Organization<br />Sandbox x3027"]:::emerald
IDENTITYAWSSANDBOXACCOUNTS["Account per User"]:::emerald
IDENTITYAWSSERVICES["AWS Organization<br />Services x6953"]:::orange
IDENTITYAWSSERVICESACCOUNTS["Account per Workload"]:::orange
IDENTITYAWSSTEALTHOPS["(Multiple) AWS Organizations<br />Off-the-grid workloads"]:::slate
IDENTITYAWSBILLING --> IDENTITYAWSSERVICES
IDENTITYAWSSERVICES --> IDENTITYAWSSERVICESACCOUNTS
IDENTITYAWSBILLING --> IDENTITYAWSSANDBOX
IDENTITYAWSSANDBOX --> IDENTITYAWSSANDBOXACCOUNTS
IDENTITYAWSBILLING --> IDENTITYAWSDEDICATEDDEV
IDENTITYAWSDEDICATEDDEV --> IDENTITYAWSDEDICATEDDEVACCOUNTS
IDENTITYAWSBILLING --> IDENTITYAWSDEDICATEDPRD
IDENTITYAWSDEDICATEDPRD --> IDENTITYAWSDEDICATEDPRDCONTROL
IDENTITYAWSDEDICATEDPRD --> IDENTITYAWSDEDICATEDPRDACCOUNTS
IDENTITYAWSBILLING --> IDENTITYAWSDEDICATEDPUBSEC
IDENTITYAWSDEDICATEDPUBSEC --> IDENTITYAWSDEDICATEDPUBSECCONTROL
IDENTITYAWSDEDICATEDPUBSEC --> IDENTITYAWSDEDICATEDPUBSECACCOUNTS
IDENTITYAWSBILLING --> IDENTITYAWSBLACKOPS
IDENTITYAWSBLACKOPS --> IDENTITYAWSBLACKOPSACCOUNTS
IDENTITYAWSBILLING --> IDENTITYAWSSTEALTHOPS

```

```

classDef slate fill:cbd5e1,stroke:475569,stroke-width:1px;
classDef red fill:fca5a5,stroke:dc2626,stroke-width:1px;
classDef orange fill:fdba74,stroke:ea580c,stroke-width:1px;
classDef yellow fill:fcd34d,stroke:ca8a04,stroke-width:1px;
classDef emerald fill:6ee7b7,stroke:059669,stroke-width:1px;
classDef cyan fill:67e8f9,stroke:0891b2,stroke-width:1px;
classDef sky fill:7dd3fc,stroke:0284c7,stroke-width:1px;
classDef violet fill:c4b5fd,stroke:7c3aed,stroke-width:1px;
classDef fuchsia fill:f0abfc,stroke:c026d3,stroke-width:1px;

```

GCP Organizations

Current State

```

mermaid
graph LR

```

```

IDENTITYGCPBILLING["GCP Billing Account"]
IDENTITYGCPDEDICATEDDEV["GCP Organization<br />Dedicated Dev"]:::yellow
IDENTITYGCPDEDICATEDPRD["GCP Organization<br />Dedicated Prd"]:::red
IDENTITYGCPPRODUCTSAAS["GCP Organization<br />gitlab.com (SaaS)<br/>Exists Today"]:::red

```

```

IDENTITYGCPPRODUCTSAASREALMSFOLDER["Cloud Realms Projects<br />Managed by HackyStack<br />Exists Today"]:::slate
IDENTITYGCPPRODUCTSAASGROUPPROJECTS["Legacy Group Projects<br />Deprecate in FY25"]:::yellow
IDENTITYGCPPRODUCTSAASINFRAFOLDER["Infrastructure Folder<br />gitlab.com (SaaS) Workloads<br />Exists Today"]:::red
IDENTITYGCPSERVICES["GCP Organization<br />gitlab.services.cloud"]:::orange
IDENTITYGCPSANDBOX["GCP Organization<br />gitlab.sandbox.cloud"]:::emerald
IDENTITYGCPBILLING --> IDENTITYGCPDEDICATEDDEV
IDENTITYGCPBILLING --> IDENTITYGCPDEDICATEDPRD
IDENTITYGCPBILLING --> IDENTITYGCPPRODUCTSAAS
IDENTITYGCPPRODUCTSAAS --> IDENTITYGCPPRODUCTSAASINFRAFOLDER
IDENTITYGCPPRODUCTSAAS --> IDENTITYGCPPRODUCTSAASGROUPPROJECTS
IDENTITYGCPPRODUCTSAAS --> IDENTITYGCPPRODUCTSAASREALMSFOLDER
IDENTITYGCPPRODUCTSAASREALMSFOLDER -. "Migrate services-realm to <br />new org in FY25" .-. IDENTITYGCPSERVICES
IDENTITYGCPPRODUCTSAASREALMSFOLDER -. "Migrate sandbox-realm to <br />new org in FY25" .-. IDENTITYGCPSANDBOX
IDENTITYGCPBILLING --> IDENTITYGCPSERVICES
IDENTITYGCPBILLING --> IDENTITYGCPSANDBOX

```

```

classDef slate fill:cbd5e1,stroke:475569,stroke-width:1px;
classDef red fill:fca5a5,stroke:dc2626,stroke-width:1px;
classDef orange fill:fd8b74,stroke:ea580c,stroke-width:1px;
classDef yellow fill:fcd34d,stroke:ca8a04,stroke-width:1px;
classDef emerald fill:6ee7b7,stroke:059669,stroke-width:1px;
classDef cyan fill:67e8f9,stroke:0891b2,stroke-width:1px;
classDef sky fill:7dd3fc,stroke:0284c7,stroke-width:1px;
classDef violet fill:c4b5fd,stroke:7c3aed,stroke-width:1px;
classDef fuchsia fill:f0abfc,stroke:c026d3,stroke-width:1px;

```

Future State

```

mermaid
graph LR

```

```

IDENTITYGCPBILLING["GCP Billing Account"]
IDENTITYGCPDEDICATEDDEV["GCP Organization<br />Dedicated Dev"]:::yellow
IDENTITYGCPDEDICATEDPRD["GCP Organization<br />Dedicated Prd"]:::red
IDENTITYGCPPRODUCTSAAS["GCP Organization<br />SaaS Stg/Prd (gitlab.com)<br />Managed by config mgmt"]:::red
IDENTITYGCPSERVICES["GCP Organization<br />Services (gitlab.systems)<br />Managed by infractl"]:::orange
IDENTITYGCPSANDBOX["GCP Organization<br />Sandbox (gitlab.sandbox.cloud)<br />Managed by HackyStack"]:::emerald

```

```

IDENTITYGCPBILLING --> IDENTITYGCPDEDICATEDDEV
IDENTITYGCPBILLING --> IDENTITYGCPDEDICATEDPRD
IDENTITYGCPBILLING --> IDENTITYGCPPRODUCTSAAS
IDENTITYGCPBILLING --> IDENTITYGCPSERVICES

```

IDENTITYGCPBILLING --> IDENTITYGCPSANDBOX

```
classDef slate fill:cbd5e1,stroke:475569,stroke-width:1px;
classDef red fill:fca5a5,stroke:dc2626,stroke-width:1px;
classDef orange fill:fd8b74,stroke:ea580c,stroke-width:1px;
classDef yellow fill:fcd34d,stroke:ca8a04,stroke-width:1px;
classDef emerald fill:6ee7b7,stroke:059669,stroke-width:1px;
classDef cyan fill:67e8f9,stroke:0891b2,stroke-width:1px;
classDef sky fill:7dd3fc,stroke:0284c7,stroke-width:1px;
classDef violet fill:c4b5fd,stroke:7c3aed,stroke-width:1px;
classDef fuchsia fill:f0abfc,stroke:c026d3,stroke-width:1px;
```

Shared Responsibilities

We use a shared responsibility model for cloud providers.

Identity Infrastructure Team

> Responsible for defining our kingdoms, castles, castle walls, and naming conventions. Focus on BLACK administrative control plane and provisioning and automation of ORANGE, YELLOW, and GREEN data infrastructure.

- Top-level AWS and GCP organization-level management, billing, IAM/RBAC
- Admin account administration and architecture
- Audit-related service accounts
- Infrastructure standards naming schema
- AWS Account creation
- GCP Project creation
- Azure sandbox user management
- Defining Identity Roles and Identity Groups
 - Managing AWS Identity Center Groups and Permission Sets
 - Managing Google Groups and User Memberships (using Identity Roles)
- Services Cloud Architecture and Automation (production-esque environments)
- Sandbox Cloud Architecture and Automation (dev/test environments)
- Tech debt reduction of legacy AWS accounts

Infrastructure Security Team

> Responsible for security of all RED data infrastructure and cloud provider best practice configuration policies across all AWS and GCP organizations.

- Top-level AWS and GCP security policies
- Resource and workload configuration audit and risk remediation
- Least privilege and role-based access control assignments for GCP Projects, Roles, and Resources in RED data organizations
- Zero touch optimization for change and configuration management
- Just-in-time access controls for resources not already managed by Identity team
- All security related to infrastructure with RED data
- GCP Infrastructure (SaaS Production) Folder and Projects

- Tech Debt Reduction of legacy GCP projects

See the team's handbook page to learn more.

Infrastructure SaaS Platforms Team

> Responsible for product hosting, reliability, and scalability of customer-facing applications and services related to the GitLab product.

- GCP Infrastructure (SaaS Production) Folder and Projects
 - Architecture, deployment, and management of all product workloads
 - Reliability of customer-facing services in the production architecture
 - Management of GitOps deployments using config-mgmt and runbooks
- Runway Infrastructure for Development Teams

See the team's handbook page to learn more.

Services Cloud

Each team that deploys infrastructure resources is responsible for managing their own infrastructure workloads and DevOps operations using industry best practices.

In other words, the Security team provides the scaffolding for your castle and provides hardened castle walls, while your team is responsible for anything you build inside the castle walls.

Sandbox Cloud Users (Engineers)

Each user is responsible for creating and destroying your own workloads.

See the Sandbox Cloud handbook page to learn more.

SECTION: security/identity/kingdoms/_index.md

Business Kingdom

The GitLab Tech Stack has a comprehensive list of all of the SaaS applications and vendors that we use. The Business Technology and IT team under the Finance division provide IT governance and procurement management for our cross-department system owners.

The primary focus for the IT team is on federating most applications with Okta SSO, with a focus on applications used across the organization, and any applications under SOX compliance or related to Finance, Legal, People, and Sales functions.

Learn more on the tech stack handbook page and Okta handbook page.

Cloud Kingdom

We use Amazon Web Services (AWS) and Google Cloud Platform (GCP) at GitLab, with a few Microsoft-specific sandbox use case workloads running in Azure and a small GitLab SaaS Runner workload running in Oracle Cloud Infrastructure (OCI).

Each team is responsible for the workloads in their respective child AWS accounts, GCP projects, etc.

The Cloud Kingdom is managed by Security Identity with collaboration from counterparts in Infrastructure Security, Infrastructure, and SIRT. All access management is handled through standard baseline entitlements, access requests for production access, and Sandbox Cloud for non-production access and dev/test accounts or projects.

See the Identity Infrastructure handbook page to learn more.

Product SaaS Production (product-prd) Kingdom

The Product Tech stack refers to all of the infrastructure packages, services, and software that we use to any host GitLab.com SaaS, GitLab Dedicated, GitLab product source code and related services, and any customer-facing services related to our product.

The Infrastructure Production Architecture handbook page has more details on how services are managed. See the Services Catalog for a non-exhaustive list of included services. You can also see the infrastructure-as-code configuration in the config-mgmt repository.

Our counterparts in the Infrastructure department are responsible for the architecture, configuration, and management of the Product Stack.

Product Dedicated (product-ded) Kingdom

The Dedicated Product Kingdom is managed by the Environment Automation team.

You can learn more on the GitLab Dedicated Group handbook page.

Black Ops Kingdom

We use Access Level Wristband Colors to provide separate BLACK user accounts for admin access. All admin accounts are managed with GitOps in an upstream control plane with the gitlab.black domain name. In alignment with the ops.gitlab.net nomenclature for our product kingdom configuration management, the admin-level configuration is managed in the ops.gitlab.black self-managed GitLab instance that we refer to as Black Ops (homeage to stealth operations, not intended as a military reference).

The Black Ops kingdom is managed by the Identity Infrastructure team.

mermaid
graph TB

subgraph Self Service Custom App Infrastructure

IDENTITYPLATFORMHACKYSTACK["HackyStack
Infrastructure Management
Sandbox and Ser
Orgs"]

```
IDENTITYPLATFORMACCESSCTL["Identity Platform<br />Access Control (accessctl)<br />RBAC Policy Management<br />App/Group/User Provisioning"]
IDENTITYPLATFORMTRAININGMGR["Training Lab Manager<br />Product training Hands-on Labs<br />U and Group Provisioning"]
end
```

```
subgraph Identity GitOps State Management Repos
```

```
end
```

```
subgraph Identity Self Hosted Vendor Services
```

```
IDENTITYHOSTEDOPSINSTANCE["ops.gitlab.black<br />Self-Managed GitLab Instance<br />Top-Level Control Plane IaC"]
IDENTITYHOSTEDTELEPORT["Teleport<br />Bastion Cluster"]
IDENTITYHOSTEDHASHIVAULT["HashiCorp Vault<br />Secrets Manager"]
end
```

```
subgraph Identity SaaS Vendor Services
```

```
IDENTITYVENDOROKTA["Okta Tenant<br />gitlab.okta.com"]
IDENTITYVENDORGOOGWORKSPACECOM["Google Workspace Org<br />gitlab.com"]
IDENTITYVENDORGOOGWORKSPACEBLACK["Google Workspace Org<br />gitlab.black"]
IDENTITYVENDORGOOGWORKSPACEDEDICATEDDEV["Google Workspace Org<br />Dedicated Dev"]
IDENTITYVENDORGOOGWORKSPACEDEDICATEDPRD["Google Workspace Org<br />Dedicated Prod"]
IDENTITYVENDORGOOGWORKSPACESERVICESCLOUD["Google Workspace Org<br />gitlab.services.c"]
IDENTITYVENDORGOOGWORKSPACESANDBOXCLOUD["Google Workspace Org<br />gitlab.sandbox.c"]
IDENTITYVENDORNORDLAYER["NordLayer VPN<br />VPN<br />Managed by IT Security"]
end
```

```
---
```

```
## SECTION: security/identity/platform/_index.md
```

```
{{% alert title="Not Live Yet" color="warning" %}}
```

You are viewing a preview of documentation for the future state of GitLab Identity v3 (mid 2024). See the [Access Management Policy](/handbook/security/security-and-technology-policies/access-management-policy/) for the GitLab Identity v2 current state with baseline entitlements and access requests. See the roadmap in the [epics gantt chart](https://gitlab.com/groups/gitlab-com/gl-security/identity/eng/-/roadmap?state=all&sort=startdateasc&layout=QUARTERS&timeframerangetype=THREYEARS&group=gitlab-com/gl-security/identity/eng&progress=WEIGHT&showprogress=true&showmilestones=false&milestone=ALL&showlabels=true).

```
{{% /alert %}}
```

Identity Platform Architecture

- CI/CD Pipeline
 - Manifests Stage
 - Auditlog Stage
 - Provisioning Stage
 - Okta Provisioning

- Google Groups Provisioning
- GitLab Groups Provisioning
- GitLab Projects Provisioning
- Access Requests
- Approvals
- Access Check (accesschk) Audit
- Terraform GitOps Configuration-as-Code
 - AWS Configuration
 - GCP Configuration
 - Okta Configuration

User Guides

- Admin Guide
- Application Configuration Guide
- Audit and Compliance Guide
- Change Management Guide
- Developer Guide
- Incident Response Guide
- Manager Guide
- Offboarding Ops Guide
- Onboarding Ops Guide
- Policy Management Guide
- Team Member End User Guide

Why It Exists

We use Terraform with a GitOps CI/CD pipeline for managing the configuration and resources in each platform/vendor (ex. Okta Settings and Okta Applications), and specifying which groups are assigned to each application/resource/permission in each respective platform (ex. Okta application groups, GCP project roles, etc). We believe that configuration and state management auditlogs are much easier to audit without all of the user membership changes, so we use Access Control to keep those changes separate and provide improved automation user experience for those use cases.

In other words, it's not realistic to have every user perform self-service Terraform changes for access requests.

The Identity Engineering team has created a standardized group and user management architecture that is used for role-based access control. Each of the standardized roles are used in combination with Groups in various systems to uniformly assign access to a known list of users that are managed with centralized policies and change management processes.

The Identity Platform is designed to use the API for each of the vendors and provide the integration plumbing between them using policy files and manifests that are stored in a centrally managed GitLab repository. Since we maintain a centralized database (via Git), we can provide a unified policy management, streamlined user experience, and provide 90%+ automation for onboarding, access requests, career mobility, and offboarding.

While many vendors have partial capabilities and some overlap, the ease-of-use and integrations

vary drastically and we have had a lot of inefficiency problems in Identity v2. Since Group management is at the heart of the problem, the Identity Platform is primarily focused on group user management automation that is used downstream in vendor configurations that we automate using Terraform where possible.

Open Source

Although the risks that we need to solve are confidential, we believe in open sourcing the best practice documentation and tools to solve those risks after we have mitigated the risk to give back to the community and inspire other companies.

We are stronger and more secure together.

Our Identity Platform open source projects can be explored at <https://gitlab.com/gitlab-identity>. Our team members also maintain side project packages that are useful dependencies and development helpers at <https://gitlab.com/provisionesta>.

Terminology

Identity Types

> Okta User Attribute: rbactype

We have different categories of users (ex. employees, contractors, service accounts, system administrators) that need birthright access to various systems. We use our access level wristbands color coding to specify each Okta user's type as blue, purple, gray, brown, or black.

Identity Roles

> Okta User Attribute: rbacrole

An Identity Role is a standardized snake case format for the functional team that the user is on or job title, as it relates to access control and permissions.

This is a next generation iteration of a GitLab Identity v2 job family and role-based baseline entitlements.

Each role uses a syntax of {departmentslug}{functionalteamslug}{specificroleifapplicable}. For example, if your department is Infrastructure, the RBAC slug is infra.

The job title of Site Reliability Engineer is too vague for IAM/RBAC purposes since we have multiple functional teams of Site Reliability Engineers that should have different levels of access.

We have defined RBAC slugs for each functional team in Infrastructure that include the infra prefix:

- infraanalytics
- infrapeopleleader

- infraplatformsleader
- infrascalabilityleader
- infraengleader
- infradedgeneral
- infradedenvautomation
- infradedswitchboard
- infradeduspubsec
- infradedext
- infradeployment
- infrafoundations
- infraobservability
- infraops
- infraorchestration
- infrapractices

Each of these functional teams usually has 1-10(ish) team members that report to one or two managers. Some functional teams may be larger (ex. product manager, sales roles, etc).

From a policy perspective, we associate a user with a role based on their manager in most cases, or a specific job title or a named user handle if needed.

There is no need for a specific role for most of these teams (no IAM difference between the Site Reliability Engineer title and Engineering Manager title). For teams that have approval permission requirements, we will suffix engineer, manager, leader, etc as appropriate. We may also suffix the region for certain roles (ex. salesentamereastnortheast). For roles that aren't necessarily on a specific team, general (Staff/Principal Engineers across multiple functions), ext (contractors with least privilege access), and others at the Identity Team's naming convention discretion.

The team manager and department leadership is responsible for naming their functional teams. The Identity team is responsible for parsing the handbook pages or provided organization chart documentation for each team and creating the short hand standardized abbreviation nomenclature.

As our organization structure ebbs and flows, we have 200-250 unique Identity Roles at any given time. See all of the roles in the policies and manifests repositories.

Division/Function	Identity Roles	Upstream Data Source
Administrators	Policies	Identity Engineering
Executive	Policies	Identity Engineering
Finance	Policies	Managers and Job Titles
Legal	Policies	Identity Engineering
Marketing	Policies	Department Names
People	Policies	Handbook Page and Manager
Sales	Policies	Sales EBA Team and Department/Manager
Product Development	Policies	DevOps Stages / YAML
Product Production	Policies	Handbook Page
Security	Policies	Handbook Page
Service Accounts	Policies	Identity Engineering

Identity Organization Units

The goal of creating Identity Roles is to implement role-based access control (RBAC) for application and group assignment, however it can be tedious and inefficient to add every single role to each application.

For less granular permissions or nonsensitive access, we can grant access to an organization unit instead of a long list of roles.

An Identity Organization Unit (OU) is a grouping of two or more Identity Roles for higher-level groups that are useful for granting access to entire divisions, departments, sub-departments, teams, regional groups or other functional groups. The Identity team is respo